Pagemark 0.13.1 Android mobile audit

Version 0.13.1

Commit e42cc26

2026-10-14

Revision 1.1

Mobile Application Release Audit - Pagemark (Android)

Version 0.13.1 (2022), commit e42cc26 = tag v0.13.1. Platform: Android only (iOS out of scope, scaffolding). Environment: production candidate. Artifacts: Pagemark-0.13.1-arm64.apk sha256 3a0f7e78...351be9; armv7.apk f5151fdc...ded0b4; play.aab fd5ee9b5...016b0734. Evidence mode: artifact + static + runtime smoke on one Android 17 x86_64 emulator (arm64 APK, ABI-translated) + unit/widget suite. No real phone. Identity gate: PASS. Audited 2026-10-14. Store policy checked 2026-10-14: developer.android.com/google/play/requirements/target-sdk (page dated 2026-10-01). MASVS: control groups used by name; IDs not cited.

DECISION

- GitHub sideload APKs: CONDITIONAL GO. No blocker, no S3+ finding.
- Google Play upload: CONDITIONAL NO-GO until the Data safety form is checked (MOB-PRV-0002) and a real-device pass is done.

Coverage: ~24 controls tested (PASS/PASS-WARN), 0 FAIL; NOT TESTED or MANUAL REVIEW: fresh install/removal, navigation/state, TalkBack, device matrix, clipboard/recents, real-phone performance, Data safety. See coverage.md. Scores (coverage): Security 99 (~70%), Privacy 98 (~50%), Store 97 (~40%), Reliability 100 (~30%), UX/Perf not scored (emulator only). Counts: blockers 0, S4 0, S3 0, S2 1, S1 4, S0 1 (accepted).

Findings

- MOB-PRV-0002 S2 (store) Data safety draft omits ML Kit scanner telemetry - manual review
- MOB-PRV-0001 S1 Privacy policy permission list and "Drive backups" wording stale
- MOB-BLD-0003 S1 APK v2-only signature, no rotation lineage
- MOB-AND-0004 S1 sqlite3_flutter_libs +eol; no vuln scan
- MOB-STORE-0005 S1 PLAY_STORE.md checklist stale, feature graphic missing
- MOB-SEC-0006 S0 locked DB unencrypted - owner-accepted

Passed highlights

Not debuggable; backup and device-transfer off; no cleartext or custom TLS; https hosts only; Play AAB has no install permission; target 36 and 16 KB alignment OK; same signing cert on both APKs; PIN PBKDF2 150k + salt + lockout; backup AES-256-GCM; analyze clean; 295 tests pass. Runtime: 0 crashes/ANRs, upgrade keeps data, offline launch and 2.0 text scale render cleanly, 0 OSV vulnerabilities in 187 packages.

Missing for a full GO

Device pass (MANUAL_TEST_PLAN.md: timer, folder backup to cloud, fingerprint, notifications, TalkBack, updater, upgrade from 0.13.0), logcat/clipboard/recents check, scanner traffic capture, real-phone performance numbers, and verification that the 0.13.1 fixes for PGM-300/302/320 work on a device.

Details: findings/*.md, coverage.md, artifact/.

MOB-AND-0004 - Dependency sqlite3_flutter_libs is on its "+eol" release; OSV scan found no known CVEs

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

The package version string marks end of life; the bundled libsqlite3.so will not receive upstream updates through it. OSV batch query of all 187 locked pub packages returned no vulnerabilities (artifact/sbom-pub.txt); the concern is maintenance only. Remediation: move to the maintained sqlite3 native-assets path (sqlite3 ^3.x is already a dependency) and rerun the scan. Verify: pubspec has no +eol package and the OSV scan is clean.

MOB-BLD-0003 - Release APK signed with APK Signature Scheme v2 only (no v3/rotation lineage)

Severity S1 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** []

apksigner: v1 false, v2 true, v3 false. Valid for minSdk 24. Without v3 a compromised or lost key cannot be rotated for sideload users, and CLAUDE.md already warns that losing the key blocks in-place upgrades. Play App Signing covers the Play build, not the GitHub APKs. Remediation: keep the keystore backed up (NAS script exists); optionally sign with v3 so a rotation lineage can be added later. Verify: apksigner verify shows v3 true.

MOB-PRV-0001 - Privacy policy permission list and Drive wording do not match the shipped manifest

Severity S1 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** []

Merged manifest also holds VIBRATE, WAKE_LOCK, RECEIVE_BOOT_COMPLETED, FOREGROUND_SERVICE, USE_FINGERPRINT (from plugins/WorkManager/notifications); the policy lists none of them. The Locked-library paragraph still says exports include "Drive backups", but Drive backup was removed in 0.8.2. Remediation: list the extra permissions with one-line reasons (or strip unused ones with tools:node="remove" if confirmed unused, e.g. FOREGROUND_SERVICE), replace "Drive backups" with "folder backups". Verify: aapt2 dump badging vs the policy list.

MOB-PRV-0002 - Play Data safety draft does not address ML Kit barcode scanner telemetry

Severity S2 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** [store]

PRIVACY.md admits Google's ML Kit "may report anonymous technical information to Google", yet the Data safety answers say nothing is collected except lookups. Google can flag a form that omits SDK collection. Unverified at runtime (no traffic capture), so MANUAL REVIEW. Remediation: capture the scanner's network traffic once on a device, then declare diagnostics/device identifiers accordingly (or confirm none), and align both documents. Verify: traffic log + Play Console form.

MOB-SEC-0006 - Locked library is not encrypted at rest (owner decision)

Severity S0 | **Status** accepted-risk | **Confidence** high | **Basis** static | **Blockers** []

The PIN gates the UI; the SQLite file is plain inside app-private storage (backup, adb and cloud transfer disabled). Owner declined SQLCipher on 2026-10-12; recorded, not re-proposed. Exposure needs a rooted device or forensic access; the encrypted backup option covers exported copies.

MOB-STORE-0005 - PLAY_STORE.md open items are stale (refers to 0.7.1) and the feature graphic is still missing

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Checklist still says verify 0.7.1 fixes and regenerate screenshots; 1024x500 graphic not made. Remediation: refresh the checklist for 0.13.x/1.0.0 and create the graphic. Verify: all listing assets present in Play Console.

Coverage - Pagemark 0.13.1+22, Android (sideload arm64 APK + play AAB), evidence mode: artifact + static + runtime smoke on Android 17 x86_64 emulator (arm64 APK, ABI-translated) + test suite

Method tags: [artifact] [static] [runtime-suite] (unit/widget tests only, no device). | Control | State | Evidence | |---|---|---| | 01 identity: pkg com.axialforge.pagemark, 0.13.1 (2022), target/compile 36, min 24, arm64 | PASS [artifact] | artifact/badging.txt | | 01 identity gate: tag v0.13.1 == HEAD e42cc26, tree clean, APK built after commit | PASS [static] | git rev-parse | | 02 not debuggable, no debuggable attr | PASS [artifact] | merged-manifest.txt | | 02 signing release key (CN=Pagemark), same cert on arm64+armv7, key.properties gitignored | PASS-WARN [artifact] MOB-BLD-0003 | signing.txt | | 02 R8 mapping present; no secrets/staging URLs found (hits are license/library strings) | PASS-WARN [artifact] | secret-smells.txt | | 02 16 KB page alignment of .so | PASS [artifact] | zipalign -P 16 OK | | 02 play AAB lacks REQUEST_INSTALL_PACKAGES | PASS [artifact] | AAB manifest grep | | 03 upgrade: 0.13.1 installed over existing emulator install, data kept (library shows Dune) | PASS [runtime] | rt-launch.png, rt-package.txt | | 03 fresh install, removal/reinstall, upgrade from a published release | NOT TESTED; migrations covered by suite [runtime-suite] | test.txt | | 05/08 text scale 2.0 on Library: no overflow or clipping | PASS [runtime] | rt-font2.png | | 11/20 launch in airplane mode, no crash; process kill then relaunch restores app | PASS [runtime] | rt-offline.png, logcat 0 fatal | | 07 back/rotation/state restore, deep paths | NOT TESTED | | | 04,06,08 (TalkBack),09 (device matrix: one emulator only) | NOT TESTED / MANUAL REVIEW (MANUAL_TEST_PLAN.md) | | | 10 performance: cold start 2.8-4.4 s, PSS 231 MB (emulator, ABI translation, not representative) | PASS-WARN [runtime] MANUAL REVIEW on real phone | rt-perf.txt | | 12 local storage: allowBackup=false, extraction rules exclude all | PASS [artifact] | merged-manifest.txt | | 12 locked DB unencrypted | accepted-risk MOB-SEC-0006 | | | 12/15 PIN PBKDF2-SHA256 150k, random 16B salt, attempt limiting, const-time compare; backup AES-256-GCM | PASS-WARN [static] | lib/lock.dart, crypto_backup.dart | | 12 logcat: 0 fatal/ANR, no PIN/title/token content from the app; run-as refused (not debuggable) | PASS [runtime] | rt-logcat.txt | | 12 clipboard, recents thumbnail (FLAG_SECURE on lock) | NOT TESTED (static only) | | | 13 network: only https hosts, no cleartext config, no custom TrustManager | PASS [static] | grep lib | | 14 backend | N/A (no backend, no accounts) | CLAUDE.md, lib grep | | 15 accounts / account deletion | N/A (no accounts) | | | 17 permissions (runtime-granted set matches manifest; Android 17 auto-grants ACCESS_LOCAL_NETWORK to this older target, not declared) : INTERNET, CAMERA, BIOMETRIC, POST_NOTIFICATIONS justified; extras | PASS-WARN MOB-PRV-0001 | badging.txt | | PLATFORM exported components: MainActivity (MAIN+SEND text, whitelisted), others permission-guarded or unexported | PASS-WARN [artifact] (untrusted-intent handling static only) | merged-manifest.txt | | 18 deps: 187 pub packages, OSV query: 0 known vulnerabilities; SBOM list; sqlite3_flutter_libs +eol | PASS-WARN [artifact] MOB-AND-0004 | sbom-pub.txt | | 19 tamper/resilience | N/A for threat model (local hobby app) | | | 21 telemetry: none declared; no analytics SDK | PASS [static] | pubspec.yaml | | 22 target API 36 meets Play rule (new apps/updates need 36 from 2026-08-31; page dated 2026-10-01) | PASS [artifact] | developer.android.com/google/play/requirements/target-sdk | | 22 Data safety, content rating, declarations | MANUAL REVIEW MOB-PRV-0002 | | | 23 listing claims vs behaviour | PASS-WARN [static] MOB-STORE-0005 | PLAY_STORE.md | | Suite: flutter analyze clean; flutter test 295 pass, 1 skip | PASS [runtime-suite] | analyze.txt, test.txt |